

SIMATS ENGINEERING

ASSESSMENT TOOL III – Penetration testing Task

1. theHarvester Reconnaissance – tesla.com

Objective

To perform passive reconnaissance on the authorized domain tesla.com and identify publicly available information such as email addresses, subdomains, hostnames, IP addresses, and URLs.

Tool Used - theHarvester

Commands

Check available options: theHarvester -h

Perform reconnaissance: theHarvester -d tesla.com -b crtsh

You can also save the results: theHarvester -d tesla.com -b crtsh -f tesla_report

Information Collected

TheHarvester can identify:

- Email addresses – publicly exposed employee email addresses
- Subdomains – additional domains belonging to Tesla
- Hostnames – names of internet-facing systems
- IP addresses – addresses associated with discovered hosts
- URLs – publicly indexed web resources
- Other OSINT – information available through supported public sources

Observation and Analysis

The discovered information helps identify the organization's external attack surface.

For example:

Email addresses → targeted phishing/credential attacks

Subdomains → additional systems to investigate

Hostnames → identify server roles

IP addresses → identify network locations

URLs → identify publicly accessible applications

An attacker can combine these findings. For example, discovering a subdomain may reveal a hostname, which can resolve to an IP address. The IP address can then be checked for exposed services during later authorized testing.

Security Risks

1. Exposed employee emails: May be used for targeted phishing and password attacks.
2. Unnecessary subdomains: Increase the number of publicly accessible systems.
3. Development/test subdomains: May have weaker security controls.
4. Hostnames: Can reveal server roles such as mail, API, VPN, or administration.
5. Externally hosted services: May introduce third-party security and configuration risks.
6. Public URLs: Can reveal additional applications and entry points.

Recommended Security Controls

- Remove unnecessary public subdomains.
- Regularly review DNS and certificate records.
- Remove abandoned or unused external services.
- Restrict development and administrative systems.
- Minimize unnecessary public information.
- Review third-party/cloud-hosted services.
- Educate employees about targeted phishing.
- Maintain an external attack-surface inventory.

Findings for Further Testing

The following findings should be validated during later penetration-testing phases:

- Interesting or unexpected subdomains
- Login and authentication portals
- Development/test environments
- Administrative interfaces
- Externally hosted services
- Hosts using outdated technologies

Conclusion

theHarvester demonstrates that an attacker can collect significant information about an organization without directly exploiting its systems. Publicly exposed emails, subdomains, hostnames, IP addresses, and URLs can be combined to build an external attack-surface map. Reducing unnecessary public information and regularly monitoring external assets can make reconnaissance more difficult for attackers.

```
kali@kali:~$ theHarvester -h
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* theHarvester 4.8.2
* Coded by Christian Martorella
* Edge-Security Research
* cmartorell@edge-security.com
*****
usage: theHarvester [-h] -d DOMAIN [-l LIMIT] [-s START] [-p] [-s] [--screenshot SCREENSHOT] [-v] [-e DNS_SERVER] [-w]
theHarvester is used to gather open source intelligence (OSINT) on a company or domain.

options:
  -h, --help            show this help message and exit
  -d, --domain DOMAIN    Company name or domain to search.
  -l, --limit LIMIT      Limit the number of search results. default=500.
  -s, --start START      Start with result number X. default=0.
  -p, --proxies           Use proxies for requests, enter proxies in proxies.yaml.
  -s, --shodan            Use Shodan to query discovered hosts.
  --screenshot SCREENSHOT Take screenshots of resolved domains specify output directory: --screenshot output_directory
  -v, --virtual-host       Verify host name via DNS resolution and search for virtual hosts.
  -e, --dns-server DNS_SERVER DNS server to use for lookup.
  -t, --take-over          Check for takeovers.
  -r, --dns-resolve [DNS_RESOLVE] Perform DNS resolution on subdomains with a resolver list or passed in resolvers, default False
  -n, --dns-lookup         Enable DNS server lookup, default false.
  -c, --dns-brute          Perform a DNS brute force on the domain.
  -f, --filename FILENAME Save the results to an XML and JSON file.
  -w, --wordlist WORDLIST Specify a wordlist for API endpoint scanning.
  -a, --api-scan           Scan for API endpoints.
  -q, --quiet             Suppress missing API key warnings.
  -b, --source SOURCE     baidu, bing, bingapi, brave, bufferoverun, builtwith, censys, certspotter, criminal
                        intelx, leaklookup, netlas, onyphe, otx, pentesttools, projectdiscovery, rapiddns, rocketree,
                        uriscan, venacup, virustotal, whoisxml, yahoo, zoommys

[kali@kali:~$]
[kali@kali:~$] theHarvester -d tesla.com -e all
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* theHarvester 4.8.2
* Coded by Christian Martorella
* Edge-Security Research
* cmartorell@edge-security.com
*****
```

```
[!] Missing API key for bevigil.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for bufferoverun.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for censys.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for certspotter.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for criminalintelx.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for fastmail.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for github.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for hunter.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for hunterio.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for intelx.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for leaklookup.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for netlas.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for onyphe.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for otx.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for pentesttools.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for projectdiscovery.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for rapiddns.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for rocketree.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for uriscan.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for venacup.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for virustotal.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for whoisxml.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for yahoo.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for zoommys.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
```

```
[!] Missing API key for github.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for hunter.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for hunterio.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for intelx.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for leaklookup.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for netlas.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for onyphe.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for otx.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for pentesttools.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for projectdiscovery.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for rapiddns.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for rocketree.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for uriscan.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for venacup.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for virustotal.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for whoisxml.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for yahoo.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
[!] Missing API key for zoommys.
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml

[kali@kali:~$] theHarvester -d tesla.com -e all -f tesla.json
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* theHarvester 4.8.2
* Coded by Christian Martorella
* Edge-Security Research
* cmartorell@edge-security.com
*****

[+] Target: tesla.com
[+] Reporting started.
[+] JSON file saved.

[kali@kali:~$]
```

2. Nikto Assessment – testphp.vulnweb.com

Objective

To assess the authorized web application **testphp.vulnweb.com** using Nikto and identify exposed files/directories, insecure HTTP methods, server information disclosure, configuration weaknesses, and outdated components.

Tool Used - Nikto

Finding	Type	Security Impact
Server/version information	Information disclosure	Helps fingerprint the server
Exposed files/directories	Configuration weakness	May reveal sensitive information
Directory listing	Configuration weakness	Reveals application structure
Insecure HTTP methods	Configuration weakness	May allow unwanted operations

Commands Used

Basic scan: `nikto -h http://testphp.vulnweb.com`

Save the scan results: `nikto -h http://testphp.vulnweb.com -o nikto_report.txt`

For additional information: `nikto -h http://testphp.vulnweb.com -Display V`

Observations

The Nikto scan may identify findings such as:**Analysis**

1. Server Version Disclosure

If the web server reveals its software and version, an attacker can use this information to identify known vulnerabilities affecting that version.

Risk: Information disclosure.

Recommendation: Keep the server updated and minimize unnecessary version information.

2. Exposed Files and Directories

If Nikto finds backup, configuration, documentation, or other sensitive files, an attacker may be able to access information that should not be publicly available.

Risk: Information disclosure and possible unauthorized access.

Recommendation: Remove unnecessary files and restrict access to sensitive directories.

3. Directory Listing

Directory listing allows users to view the contents of a directory.

Risk: Attackers can discover application files, directories, and potentially sensitive resources.

Recommendation: Disable directory browsing unless it is specifically required.

4. HTTP Methods

Nikto may identify supported HTTP methods. Methods such as **PUT**, **DELETE**, or **TRACE** should be checked to determine whether they are unnecessarily enabled.

Manual check:

```
curl -i -X OPTIONS http://testphp.vulnweb.com/
```

Risk: Incorrectly configured methods may allow unauthorized actions.

Recommendation: Disable unnecessary HTTP methods and allow only those required by the application.

5. Outdated Components

3. DNS Enumeration – zonetransfer.me

Objective

To use the **Dig** utility to enumerate DNS records for the authorized domain **zonetransfer.me**, identify authoritative DNS servers, and check whether an unauthorized DNS zone transfer is possible.

Tool Used

Dig

1. A Record

```
dig zonetransfer.me A
```

Purpose:

The A record maps the domain to an IPv4 address.

Security relevance:

It can reveal the IPv4 address of the organization's server.

2. AAAA Record

```
dig zonetransfer.me AAAA
```

Purpose:

The AAAA record provides an IPv6 address.

Security relevance:

It may reveal additional IPv6 infrastructure that should also be included in security assessments.

3. MX Record

```
dig zonetransfer.me MX
```

Purpose:

Identifies the mail servers responsible for receiving email.

Security relevance:

An attacker can identify the organization's email infrastructure and potentially use it for further reconnaissance.

4. NS Record

dig zonetransfer.me NS

Purpose:

Identifies the authoritative DNS servers for the domain.

Security relevance:

These servers are responsible for providing authoritative DNS information.

5. CNAME Record

dig zonetransfer.me CNAME

Purpose:

Shows whether the domain or a hostname is an alias for another hostname.

Security relevance:

CNAME relationships can reveal connections between different services or infrastructure.

6. TXT Record

dig zonetransfer.me TXT

Purpose:

Displays text records, which can contain information such as email-security policies or service-verification data.

7. Identify Authoritative Servers

Use:

dig zonetransfer.me NS +short

The returned names are the authoritative DNS servers.

For example:

ns1.example.com

ns2.example.com

Record the exact servers returned by your lab output.

8. Test DNS Zone Transfer

A zone transfer can be tested against an authoritative server:

```
dig @<authoritative-server> zonetransfer.me AXFR
```

For example:

```
dig @ns1.example.com zonetransfer.me AXFR
```

If the Transfer Fails

A refusal or transfer failure indicates that the server is not allowing the requesting host to perform the transfer.

Result: No unauthorized AXFR confirmed.

If the Transfer Succeeds

A successful AXFR can return many DNS records from the zone.

Result: This represents a significant DNS configuration weakness because unauthorized users may obtain a detailed map of the domain's DNS infrastructure.

Observation and Analysis

DNS enumeration can reveal:

- IPv4 addresses
- IPv6 addresses
- Mail servers
- Authoritative DNS servers
- Hostname relationships
- Service information
- DNS zone-management information

An attacker could combine these findings:

NS records → **DNS servers**

MX records → **Mail infrastructure**

A/AAAA records → **Server IP addresses**

CNAME records → Service relationships

DNS information + port scanning → Exposed services

Therefore, DNS information can significantly assist external reconnaissance.

Risks of Unrestricted AXFR

If an unauthorized zone transfer succeeds, an attacker may obtain:

- Large numbers of hostnames
- IP addresses
- Mail servers
- Subdomains
- Server naming conventions
- Development/test systems
- Relationships between services

This can make subsequent reconnaissance much easier.

Recommended Security Controls

1. Restrict AXFR requests to authorized secondary DNS servers.
2. Configure DNS access-control lists.
3. Remove unnecessary DNS records.
4. Regularly review public DNS zones.
5. Monitor unusual DNS requests and transfer attempts.
6. Separate internal DNS information from public DNS where appropriate.
7. Keep DNS servers updated and securely configured.

Conclusion

Dig is an effective DNS reconnaissance tool. It can identify IP addresses, mail servers, authoritative DNS servers, aliases, and other infrastructure information. The most serious issue to investigate is an **unauthorized AXFR zone transfer**, because a successful transfer can expose a large amount of DNS information at once. Restricting zone transfers and regularly reviewing public DNS records can reduce information disclosure.

```
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

Session Actions Edit View Help
(kali@kali)-[~]
$ dig zonetransfer.me A
(kali@kali)-[~]
$ dig zonetransfer.me A
<<>> DIG 9.20.15-2-Debian <<>> zonetransfer.me A
;; Global options: +cmd
;; Got answer:
;; --HEADER-- opcode: QUERY, status: FORMERR, id: 38713
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available
;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags: udp: 1232
;; COOKIE: 1a3e2e2a0a3b5da6 (echoed)
;; QUESTION SECTION:
;; zonetransfer.me. IN A
;; Query time: 100 msec
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)
;; WHEN: Sun Aug 10 09:32:10 EDT 2025
;; MSG SIZE rcvd: 56

(kali@kali)-[~]
$ dig zonetransfer.me AAAA
(kali@kali)-[~]
$ dig zonetransfer.me AAAA
<<>> DIG 9.20.15-2-Debian <<>> zonetransfer.me AAAA
;; Global options: +cmd
;; Got answer:
;; --HEADER-- opcode: QUERY, status: FORMERR, id: 13753
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available
;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags: udp: 1232
;; COOKIE: 7c0a2aa480aac17d0 (echoed)
;; QUESTION SECTION:
;; zonetransfer.me. IN AAAA
;; Query time: 27 msec
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)
;; WHEN: Sun Aug 10 09:54:39 EDT 2025
;; MSG SIZE rcvd: 56

(kali@kali)-[~]
$ dig zonetransfer.me MX
(kali@kali)-[~]
$ dig zonetransfer.me MX
<<>> DIG 9.20.15-2-Debian <<>> zonetransfer.me MX
;; Global options: +cmd
;; Got answer:
;; --HEADER-- opcode: QUERY, status: FORMERR, id: 48147
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
```

```
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

Session Actions Edit View Help
(kali@kali)-[~]
$ dig zonetransfer.me SOA
(kali@kali)-[~]
$ dig zonetransfer.me SOA
<<>> DIG 9.20.15-2-Debian <<>> zonetransfer.me SOA
;; Global options: +cmd
;; Got answer:
;; --HEADER-- opcode: QUERY, status: FORMERR, id: A6769
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available
;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags: udp: 1232
;; COOKIE: e2a8b0603a068 (echoed)
;; QUESTION SECTION:
;; zonetransfer.me. IN SOA
;; Query time: 27 msec
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)
;; WHEN: Sun Aug 10 09:56:15 EDT 2025
;; MSG SIZE rcvd: 56

(kali@kali)-[~]
$ dig zonetransfer.me NS +short
(kali@kali)-[~]
$ dig zonetransfer.me nsztml.digi.ninja
<<>> DIG 9.20.15-2-Debian <<>> zonetransfer.me nsztml.digi.ninja
;; Global options: +cmd
;; Got answer:
;; --HEADER-- opcode: QUERY, status: FORMERR, id: 7280
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available
;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags: udp: 1232
;; COOKIE: 7280
;; QUESTION SECTION:
;; zonetransfer.me. IN NS
;; Query time: 27 msec
;; SERVER: 172.21.100.31#53(172.21.100.31) (UDP)
;; WHEN: Sun Aug 10 09:56:15 EDT 2025
;; MSG SIZE rcvd: 56
```

4. Enum4linux Assessment – 192.168.1.100

Objective

To assess the authorized Windows/SMB server **192.168.1.100** using **Enum4linux** and determine what information can be obtained through SMB and NetBIOS enumeration before attempting exploitation.

Tool Used - Enum4linux

1. Basic Enumeration

Run the comprehensive enumeration: `enum4linux -a 192.168.1.100`

The **-a** option performs several enumeration checks.

Individual Commands

User enumeration: enum4linux -U 192.168.1.100

Share enumeration: enum4linux -S 192.168.1.100

Group enumeration: enum4linux -G 192.168.1.100

Password policy: enum4linux -P 192.168.1.100

NetBIOS information: enum4linux -n 192.168.1.100

Use the **actual values shown in your Enum4linux output** in your final lab record.

2. User Enumeration

Command: enum4linux -U 192.168.1.100

Analysis

If usernames are exposed, attackers may use them as input for credential attacks such as password spraying.

Example attack chain:

Username discovery → password attack → account compromise

User enumeration is therefore an information-disclosure issue, particularly when combined with weak authentication controls.

Recommendation

- Restrict anonymous user enumeration.
- Use strong passwords.
- Implement account lockout/rate-limiting controls where appropriate.
- Enable MFA for supported administrative services.
- Monitor failed authentication attempts.

3. SMB Share Enumeration

Command: enum4linux -S 192.168.1.100

This may reveal available SMB shares.

Example:

Share Name	Type
------------	------

-----	----
-------	------

Public	Disk
--------	------

Documents	Disk
-----------	------

IPC\$	IPC
-------	-----

Record the actual shares from your scan.

Analysis

Excessively accessible shares can expose confidential documents, backups, scripts, or other sensitive information.

For example:

Share discovery → file access → sensitive information → further compromise

Recommendation

- Remove unnecessary shares.
- Apply least-privilege permissions.
- Restrict access to authorized users/groups.
- Regularly audit share permissions.
- Avoid storing passwords or sensitive credentials in shared folders.

4. Group Enumeration

Command: `enum4linux -G 192.168.1.100`

Analysis

Group information can reveal privileged groups such as administrators.

If an attacker identifies users belonging to privileged groups, those accounts may become high-value targets for credential attacks.

Recommendation

- Follow least privilege.
- Regularly review group membership.
- Remove unnecessary administrative privileges.
- Protect privileged accounts with stronger authentication.

5. Password Policy Enumeration

Command: enum4linux -P 192.168.1.100

Information to Check

Look for:

- Minimum password length
- Password complexity
- Password history
- Account lockout settings
- Maximum password age

Analysis

A weak password policy can make credential attacks easier.

For example:

Weak password policy + exposed usernames → increased credential-attack risk

Recommendation

Use strong password policies, appropriate account protection, and MFA where possible.

9. Overall Security Risks

The information obtained through SMB enumeration can assist attackers with:

- Username discovery
- Password attacks
- Identification of privileged accounts
- Sensitive file discovery
- Share abuse

- Vulnerability identification
- Lateral movement

The risk becomes greater when several weaknesses exist together.

10. Recommended Remediation

High Priority

1. Disable unnecessary anonymous/null-session access.
2. Restrict SMB access using firewall rules.
3. Remove unnecessary SMB shares.
4. Correct overly permissive share permissions.
5. Protect privileged accounts.

Medium Priority

6. Apply strong password policies.
7. Enable MFA where supported.
8. Patch Windows systems regularly.
9. Monitor failed SMB/authentication attempts.

Long-Term

10. Segment critical Windows systems from ordinary user networks.
11. Regularly audit SMB shares and permissions.
12. Maintain an accurate inventory of Windows systems and services.

11. Validation After Remediation

Run the enumeration again:

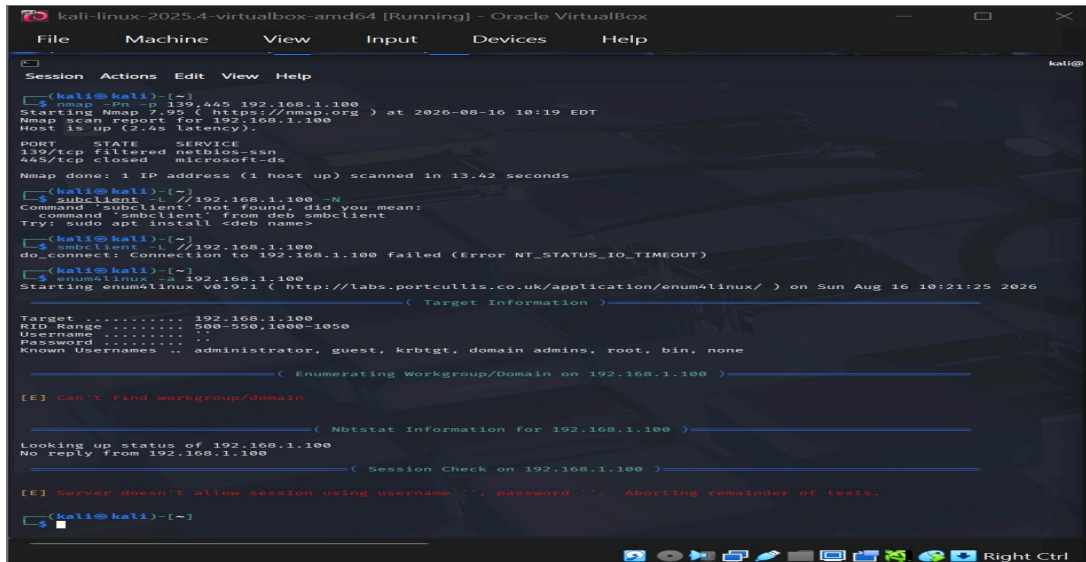
```
enum4linux -a 192.168.1.100
```

Verify that:

- Anonymous information is no longer exposed.
- Unnecessary shares are removed.
- Share permissions are restricted.
- Sensitive user/group information is protected.
- SMB is accessible only from authorized networks.

Conclusion

Enum4linux provides valuable information about a Windows/SMB environment, including **users, groups, shares, domains, NetBIOS information, and password policies**. If this information is available anonymously or unnecessarily exposed, it can assist attackers with credential attacks, privilege escalation, and lateral movement. Restricting SMB access, applying least privilege, disabling anonymous enumeration, patching systems, and using network segmentation can significantly reduce the risk.



```
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

(kali@kali)-[~]
$ nmap -p 139,445 192.168.1.100
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-16 18:19 EDT
Nmap scan report for 192.168.1.100
Host is up (2.45s latency):
PORT      STATE SERVICE
139/tcp   filtered netbios-ssn
445/tcp   closed  microsoft-ds
Nmap done: 1 IP address (1 host up) scanned in 13.42 seconds

(kali@kali)-[~]
$ subclient -i //192.168.1.100 -N
Command 'subclient' not found, did you mean:
  command 'subclient' from deb subclient
Try: sudo apt install <deb name>

(kali@kali)-[~]
$ subclient -i //192.168.1.100
do_connect: Connection to 192.168.1.100 failed (Error NT_STATUS_IO_TIMEOUT)

(kali@kali)-[~]
$ enum4linux -a 192.168.1.100
Starting enum4linux V0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun Aug 16 18:21:25 2026

( Target Information )
Target ..... 192.168.1.100
RID Range ..... 500-550,1000-1050
Username ..... 
Password ..... 
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

( Enumerating Workgroup/Domain on 192.168.1.100 )

[E] Can't find workgroup/domain

( Nbtstat Information for 192.168.1.100 )
Looking up status of 192.168.1.100
No reply from 192.168.1.100

( Session Check on 192.168.1.100 )

[E] Server doesn't allow session using username '', password ''. Aborting remainder of tests.

(kali@kali)-[~]
$
```

5. Netcat Service Banner Assessment – scanme.nmap.org

Objective

To use **Netcat (nc)** against the authorized target **scanme.nmap.org** to identify accessible TCP services and collect service banners. The collected information is analyzed to determine what technical details are voluntarily disclosed and how they may assist an attacker during reconnaissance.

Tool Used - Netcat (nc)

1. Identify Open Ports

Before connecting with Netcat, identify the accessible TCP services: `nmap -sV scanme.nmap.org`

Record the ports that are actually shown as open in your lab output.

2. Connect Using Netcat

SSH

If port 22 is open:

```
nc -v scanme.nmap.org 22
```

The service may return an SSH banner similar to:

```
SSH-2.0-OpenSSH_x.x
```

Observation:

The response identifies the SSH protocol and potentially the SSH implementation/version.

HTTP

If port 80 is open: `nc -v scanme.nmap.org 80`

Then enter: `GET / HTTP/1.1`

Host: scanme.nmap.org

Connection: close

The response may contain HTTP headers such as:

```
HTTP/1.1 200 OK
```

```
Server: ... Content-Type: text/html
```

Observation:

The HTTP response can reveal the web server, HTTP version, content type, status code, and other implementation details.

Use the **exact banner and HTTP headers returned by your current scan** as your evidence.

3. Analysis of Banner Information

SSH Banner

If the SSH service reveals an implementation such as OpenSSH, an attacker can identify the software being used.

Security impact: The information can be compared against known vulnerabilities affecting that software/version.

Classification: Usually **information disclosure**, not automatically a vulnerability.

Further validation: Verify the exact version and determine whether it is affected by any known security issues.

HTTP Response

HTTP headers can reveal information about the web server and application.

For example: Server: <server information>

This helps an attacker fingerprint the technology stack.

Security impact:

The attacker can use the information to research relevant vulnerabilities and choose more targeted testing techniques.

Classification:

Usually information disclosure unless the disclosed version is associated with a confirmed exploitable vulnerability.

5. How Attackers Could Use the Information

The information can be combined as follows:

Open Port



Service Identification



Software Identification



Version Fingerprinting



Vulnerability Research



Targeted Security Testing

For example:

Port 22 → SSH → OpenSSH → identify version → check known vulnerabilities

Similarly:

Port 80 → HTTP → web-server identification → technology fingerprinting → further web assessment

Accurate service fingerprinting reduces the uncertainty an attacker has about the target.

6. Security Risks

Information Disclosure

Service banners may disclose technical information that is not necessary for normal users.

Targeted Attacks

If an outdated version is disclosed, attackers can research vulnerabilities specific to that version.

Attack-Surface Mapping

Open services reveal which applications are externally accessible.

Increased Reconnaissance Accuracy

Combining banners with DNS, OSINT, and port-scanning information can provide a more complete picture of the target infrastructure.

7. Is Banner Disclosure a Vulnerability?

Not necessarily.

A banner such as: SSH-2.0-OpenSSH_x.x

normally represents **information disclosure**.

It becomes more serious if:

1. The exact software/version is identified.
2. The version has a known vulnerability.
3. The vulnerability is relevant to the target configuration.
4. Authorized testing confirms the weakness.

Therefore, the correct classification should be:

Banner disclosure → Information disclosure

rather than immediately claiming:

Banner disclosure → Confirmed vulnerability

8. Recommended Security Measures

1. Keep all externally exposed services patched.
2. Disable unnecessary services and ports.
3. Restrict administrative services where possible.
4. Minimize unnecessary software/version information in banners.
5. Configure web-server headers appropriately.
6. Use firewall rules to restrict access.
7. Monitor external connection attempts.

9. Validation of Remediation

After making security changes, reconnect using Netcat: `nc -v scanme.nmap.org 22`

For HTTP: `nc -v scanme.nmap.org 80`

Then compare the new banner/HTTP response with the original evidence.

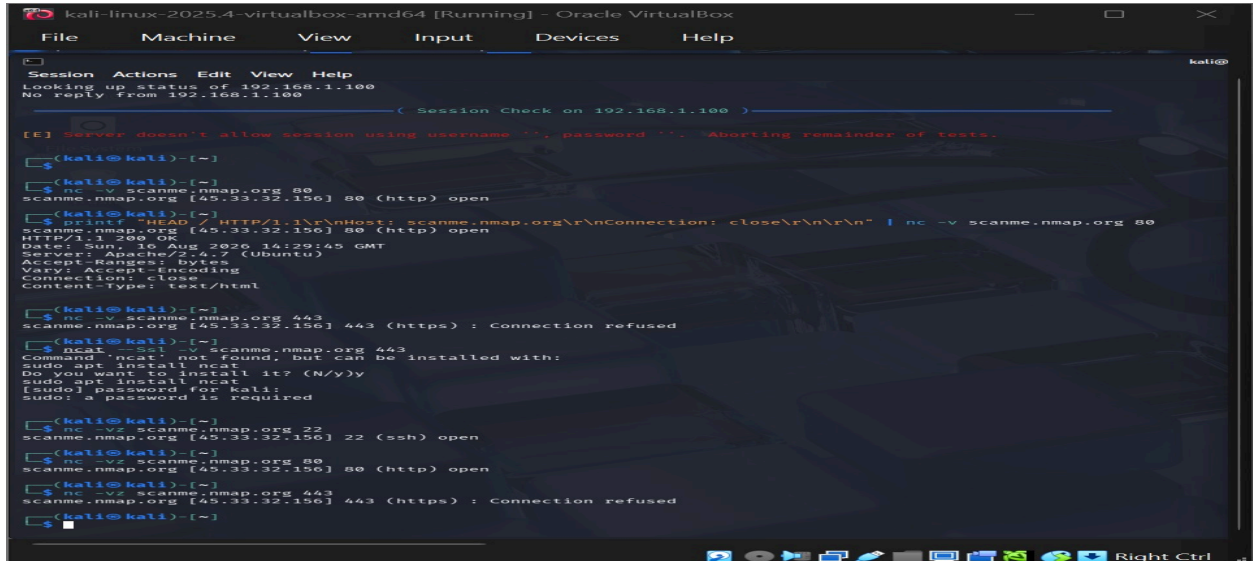
You can also check HTTP headers with: `curl -I http://scanme.nmap.org/`

The objective is to verify that unnecessary information has been reduced while required services continue to operate normally.

Conclusion

Netcat can reveal valuable information from externally accessible TCP services. Service banners may disclose the **service type, protocol, software name, version, HTTP headers, and other technical details**. Banner exposure is generally an **information-disclosure issue rather than a**

direct vulnerability. However, attackers can combine accurate service fingerprints with other reconnaissance information to identify potential weaknesses and make subsequent attacks more targeted. Therefore, organizations should minimize unnecessary banner information, keep exposed services updated, restrict unnecessary ports, and continuously monitor their external attack surface.



```
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

[+] Session Actions Edit View Help
Looking up status of 192.168.1.100
No reply from 192.168.1.100

( Session Check on 192.168.1.100 )

[!] Server doesn't allow session using username '', password ''. Aborting remainder of tests.

(kali@kali)-[~]
└─$ nc -v scanme.nmap.org 80
scanme.nmap.org [45.33.32.156] 80 (http) open

(kali@kali)-[~]
└─$ printf 'HEAD / HTTP/1.1\r\nHost: scanme.nmap.org\r\nConnection: close\r\n\r\n' | nc -v scanme.nmap.org 80
scanme.nmap.org [45.33.32.156] 80 (http) open
HTTP/1.1 200 OK
Date: Sun, 10 Aug 2020 14:29:45 GMT
Server: Apache/2.4.18 (Ubuntu)
Accept-Ranges: bytes
Vary: Accept-Encoding
Content-Type: text/html
Connection: close

(kali@kali)-[~]
└─$ nc -v scanme.nmap.org 443
scanme.nmap.org [45.33.32.156] 443 (https) : Connection refused

(kali@kali)-[~]
└─$ nc -v scanme.nmap.org 443
Command 'ncat' not found, but can be installed with:
sudo apt install ncat
Do you want to install it? (N/y)y
[sudo] password for kali:
sudo: a password is required

(kali@kali)-[~]
└─$ nc -v scanme.nmap.org 22
scanme.nmap.org [45.33.32.156] 22 (ssh) open

(kali@kali)-[~]
└─$ nc -v scanme.nmap.org 80
scanme.nmap.org [45.33.32.156] 80 (http) open

(kali@kali)-[~]
└─$ nc -v scanme.nmap.org 443
scanme.nmap.org [45.33.32.156] 443 (https) : Connection refused

(kali@kali)-[~]
└─$
```

Code of Conduct:

I G. Nithya Sree (192424103) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: G. Nithya Sree